VULNERABILITY ASSESSMENT & PENETRATION TEST

Studente: Vincenzo Lembo
Corso: Cybersecurity & Ethical Hacking
Esercitazione: W16D4 - Progetto finale
Argomento: VA/PT completo sulla macchina bersaglio Bsides Vancouver
Ambiente: Kali Linux, BSides Vancouver 2018 Workshop – UTM

---

1. Obiettivo dell'esercitazione

L'obiettivo dell'attività consiste nell'eseguire un Vulnerability Assessment e un Penetration Test sulla macchina virtuale vulnerabile *BSides Vancouver 2018 Workshop*, individuando i servizi esposti, analizzando le possibili vulnerabilità e verificando la possibilità di ottenere un accesso non autorizzato al sistema. Durante il test è stato possibile individuare informazioni sensibili tramite FTP, ottenere credenziali SSH valide e raggiungere i privilegi amministrativi di root.

---

2. Metodologia

Il test è stato suddiviso nelle seguenti fasi:

1. **Reconnaissance:** identificazione dell'indirizzo IP e dei servizi disponibili sulla macchina bersaglio.
2. **Scanning:** scansione delle porte TCP e identificazione delle versioni dei servizi.
3. **Enumeration:** analisi dei servizi FTP, HTTP, WordPress e SSH.
4. **Vulnerability Assessment:** identificazione e verifica delle debolezze di sicurezza.
5. **Exploitation:** individuazione di credenziali valide e accesso alla macchina tramite SSH.
6. **Privilege Escalation:** verifica dei privilegi dell'utente compromesso e ottenimento dell'accesso root.

Gli strumenti principali utilizzati sono stati Nmap, Metasploit Framework, il client FTP, SSH, Curl e il browser Firefox.

---

3. Reconnaissance e identificazione della macchina bersaglio

3.1 Configurazione della macchina BSides su UTM

Prima di iniziare la scansione delle vulnerabilità è stato necessario configurare correttamente la rete delle macchine virtuali.

La macchina BSides Vancouver 2018 Workshop è stata configurata tramite UTM, il software di virtualizzazione installato sul computer macOS.

Nelle impostazioni della macchina virtuale è stata selezionata la modalità:

Rete condivisa (Shared Network).

Questa modalità consente alla macchina virtuale di utilizzare la connettività di rete del Mac attraverso la rete virtuale gestita da UTM.

La macchina BSides non viene quindi collegata direttamente alla rete fisica come dispositivo indipendente, ma utilizza una rete virtuale condivisa tramite il sistema host.

La configurazione è stata necessaria per permettere la comunicazione tra la macchina bersaglio e Kali Linux all'interno dell'ambiente di laboratorio.

3.2 Configurazione della rete Kali Linux tramite DHCP

Dopo aver configurato la rete della macchina BSides, è stato necessario verificare che anche Kali Linux potesse comunicare con la stessa rete virtuale. Per questo motivo, nelle impostazioni di rete di Kali Linux è stata selezionata la configurazione automatica degli indirizzi IPv4 tramite:

DHCP (Dynamic Host Configuration Protocol).

Il DHCP è un protocollo che consente a un dispositivo di ottenere automaticamente i parametri necessari alla comunicazione in rete, tra cui indirizzo IP, maschera di sottorete e gateway. La configurazione automatica è stata preferita all'inserimento manuale di un indirizzo IP perché la rete condivisa di UTM utilizza un proprio sistema di assegnazione degli indirizzi. Impostando Kali Linux in modalità DHCP automatico, la macchina ha potuto ricevere un indirizzo compatibile con la rete virtuale utilizzata da BSides, evitando di mantenere un precedente indirizzo IP statico appartenente a una sottorete differente.

L'indirizzo IP assegnato a Kali Linux è risultato:

192.168.64.3

La rete virtuale utilizzata apparteneva alla sottorete:

192.168.64.0/24

3.3 Individuazione della rete da analizzare

Una volta configurata la connessione, è stato possibile identificare la sottorete utilizzata dall'ambiente virtuale.

La rete individuata era:

192.168.64.0/24

La notazione `/24` indica una maschera di sottorete equivalente a `255.255.255.0`.

Questo dato è stato utilizzato per definire l'intervallo di indirizzi da analizzare durante la ricerca della macchina bersaglio.

3.4 Scansione della rete per individuare la macchina BSides

Non conoscendo inizialmente l'indirizzo IP della macchina BSides, è stata eseguita una scansione della rete virtuale utilizzando Nmap.

Il comando eseguito è stato:

sudo nmap -sn 192.168.64.0/24

Il comando è composto da:

- `sudo`: esegue Nmap con privilegi amministrativi.
- `nmap`: avvia lo strumento di scansione della rete.
- `-sn`: esegue una scansione di individuazione degli host attivi, senza effettuare una scansione delle porte.
- `192.168.64.0/24`: indica la sottorete da analizzare.

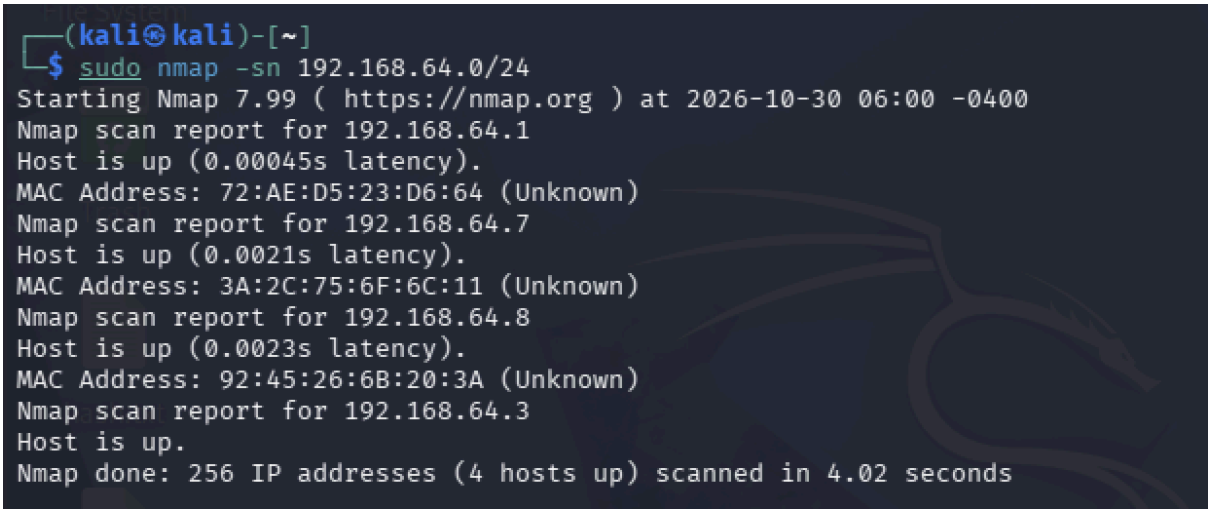
Lo scopo del comando era individuare quali dispositivi fossero attivi nella rete virtuale, per identificare successivamente la macchina BSides.

La scansione ha rilevato diversi indirizzi IP attivi, tra cui:

- 192.168.64.1
- 192.168.64.3
- 192.168.64.7
- 192.168.64.8

L'indirizzo `192.168.64.1` corrispondeva al gateway della rete virtuale, mentre `192.168.64.3` era l'indirizzo assegnato a Kali Linux.

Restavano quindi da identificare gli altri dispositivi rilevati.



3.5 Identificazione della macchina bersaglio tramite indirizzo MAC

Per distinguere la macchina BSides dagli altri dispositivi presenti nella rete è stato utilizzato l'indirizzo MAC.

L'indirizzo MAC è un identificativo associato all'interfaccia di rete virtuale.

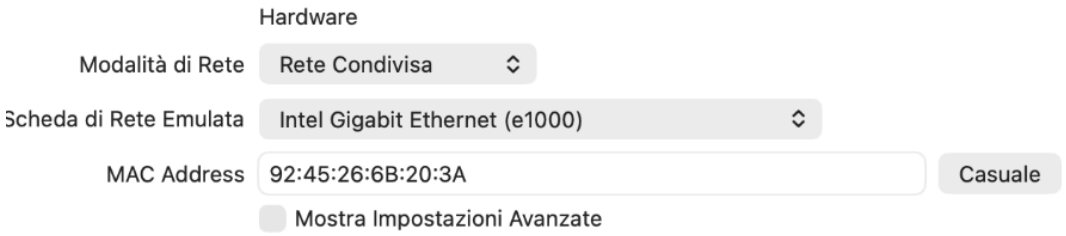
Durante la scansione Nmap, l'indirizzo IP `192.168.64.8` risultava associato al seguente indirizzo MAC:

92:45:26:6B:20:3A

Confrontando questo valore con l'indirizzo MAC configurato nelle impostazioni di rete della macchina BSides su UTM, è stato possibile identificare con certezza il dispositivo bersaglio.

L'indirizzo IP della macchina BSides Vancouver 2018 Workshop è stato quindi identificato come:

192.168.64.8



3.6 Verifica della raggiungibilità della macchina bersaglio

Dopo aver identificato l'indirizzo IP del target, è stata verificata la comunicazione tra Kali Linux e BSides.

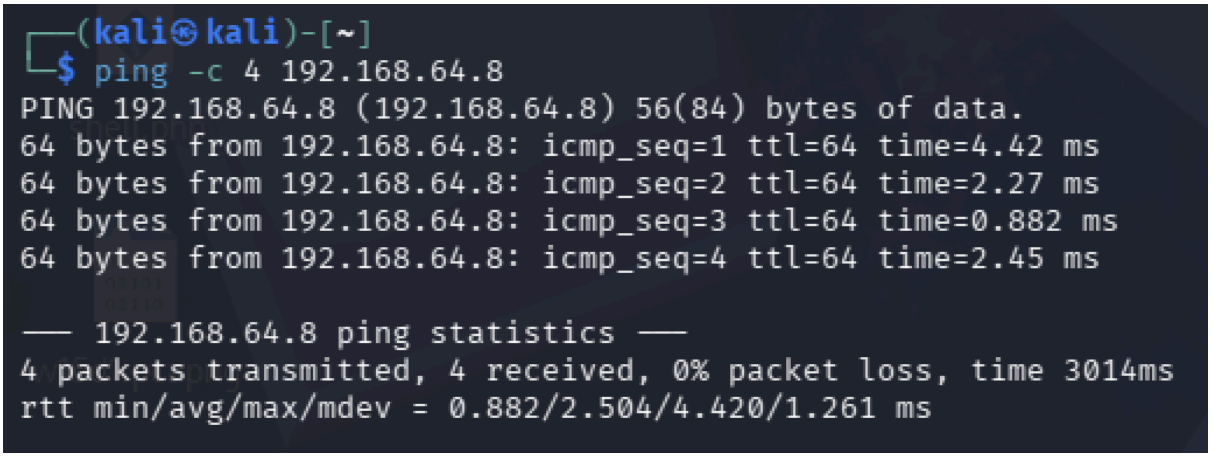
Il comando utilizzato è stato:

ping -c 4 192.168.64.8

Il comando invia quattro richieste ICMP Echo Request all'indirizzo IP specificato.

Il parametro `-c 4` limita il numero di richieste a quattro, evitando che il comando continui indefinitamente.

Questa verifica è stata utilizzata per controllare la raggiungibilità della macchina bersaglio prima di procedere con la scansione dei servizi.



4. Scansione delle porte e identificazione dei servizi

4.1 Scansione completa delle porte TCP

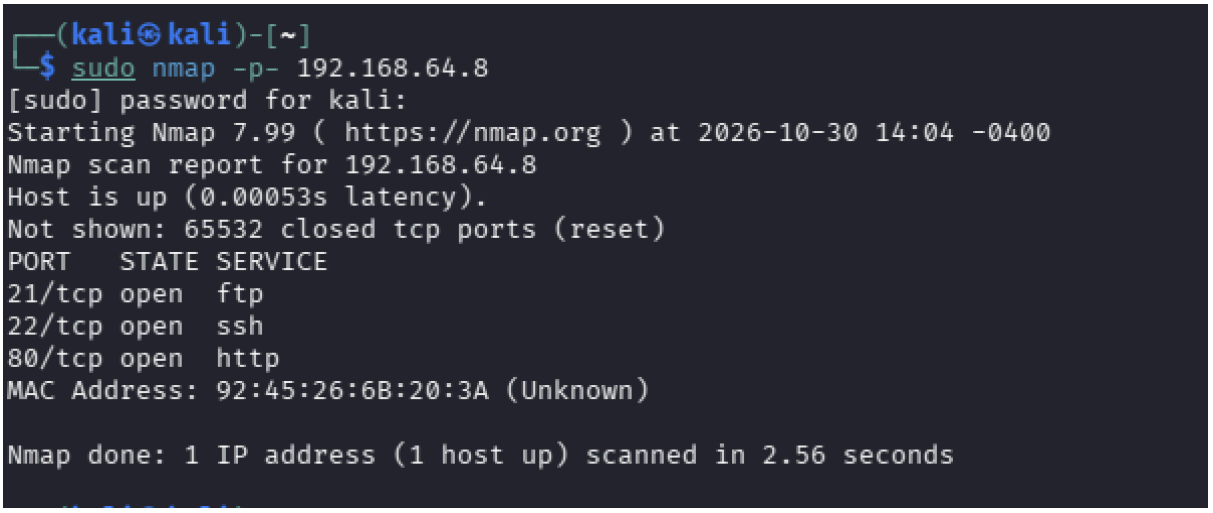
Dopo aver identificato l'indirizzo IP della macchina bersaglio, è stata eseguita una scansione delle porte TCP:

sudo nmap -p- 192.168.64.8

Il parametro `-p-` consente di analizzare tutte le 65.535 porte TCP.

La scansione ha individuato tre porte aperte:

Porta	Protocollo	Servizio
21	TCP	FTP
22	TCP	SSH
80	TCP	HTTP



4.2 Identificazione delle versioni dei servizi

Successivamente è stata effettuata una scansione per identificare le versioni dei servizi:

nmap -sV 192.168.64.8

Sono stati identificati:

- **FTP:** vsftpd 2.3.5
- **SSH:** OpenSSH 5.9p1 Debian 5ubuntu1.10
- **HTTP:** Apache 2.2.22 su Ubuntu

Il parametro `-sV` permette a Nmap di tentare l'identificazione del software e della relativa versione associata ai servizi rilevati.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV 192.168.64.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-30 06:03 -0400
Nmap scan report for 192.168.64.8
Host is up (0.00076s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.5
22/tcp open  ssh     OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 92:45:26:6B:20:3A (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.99 seconds
```

---

5. Analisi del servizio FTP

5.1 Verifica dell'accesso anonimo

Durante l'analisi della porta 21 è stato utilizzato il modulo Metasploit:

`auxiliary/scanner/ftp/ftp_anonymous`

```
   0   auxiliary/scanner/ftp/ftp_anonymous                    .                normal  No     Anonymous FTP Access Detection
```

```
msf auxiliary(scanner/ftp/ftp_anonymous) > exploit
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.35/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested re
peat operator '+' and '?' was replaced with '*' in regular expression
[+] 192.168.64.8:21       - Anonymous Read-only access ()
[+] 192.168.64.8:21       - Directory listing stored to: /home/kali/.msf4/loot/20261030091211_default_192.168.64.8_ftp.anonymous_540086.t
xt
[*] 192.168.64.8:21       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Il modulo ha individuato la possibilità di accedere al servizio FTP in modalità

anonima, con permessi di lettura. L'accesso è stato successivamente verificato manualmente:

```
ftp 192.168.64.8
```

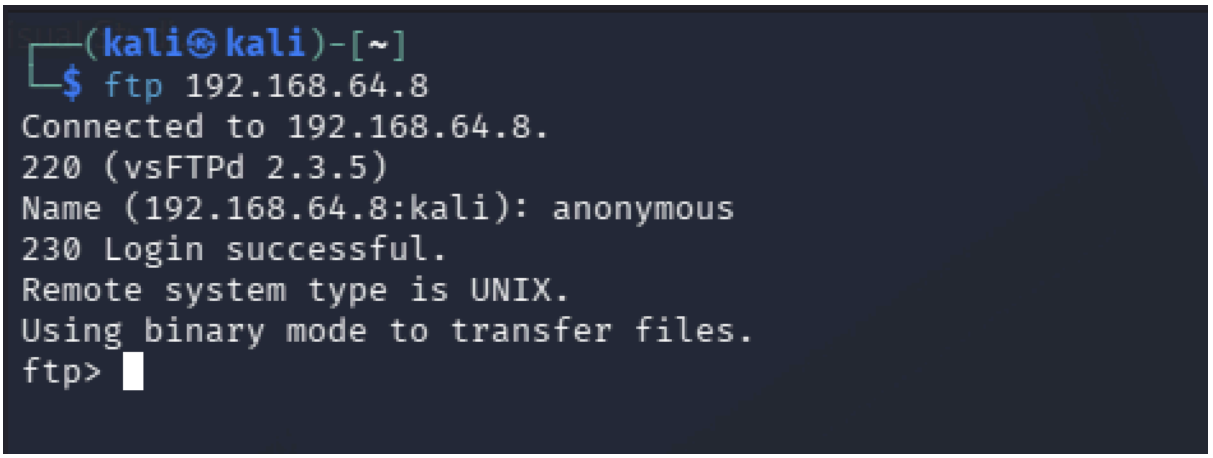
Come nome utente è stato inserito:

```
anonymous
```

Il server ha restituito:

```
230 Login successful.
```

Il risultato conferma che il servizio FTP consente l'accesso senza credenziali personali.



5.2 Individuazione di un file contenente nomi utente

Dopo aver effettuato l'accesso al server FTP, è stato esaminato il contenuto delle directory:

```
ls
```

È stata individuata una directory denominata:

```
public
```

```
ftp> ls
229 Entering Extended Passive Mode (|||62796|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
226 Directory send OK.
ftp>
```

Per accedervi è stato utilizzato:

`cd public`

Successivamente, tramite un nuovo elenco dei file, è stato individuato:

`users.txt.bk`

```
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10111|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0              31 Mar 03  2018 users.txt.bk
226 Directory send OK.
```

Il file è stato scaricato sulla macchina Kali Linux utilizzando:

`get users.txt.bk`

```
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||32229|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |***************************************************************************************|    31        2.92 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (1.97 KiB/s)
```

Successivamente è stato visualizzato mediante:

`cat users.txt.bk`

Il contenuto del file comprendeva cinque nomi utente:

- **`abatchy`**
- **`john`**
- **`mai`**
- **`anne`**
- **`doomguy`**

```
┌──(kali㉿kali)-[~]
└─$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

5.3 Vulnerabilità riscontrata

Vulnerabilità: accesso FTP anonimo con esposizione di informazioni sensibili.

Descrizione: il server FTP consente a utenti non autenticati di accedere a una directory pubblica contenente un file con nomi di account.

Impatto dimostrato: acquisizione di cinque nomi utente, successivamente utilizzati per le verifiche di autenticazione SSH.

---

6. Analisi del servizio HTTP e WordPress

6.1 Identificazione del server web

Durante la scansione iniziale con Nmap è stata individuata la porta `80/TCP` aperta, associata al servizio HTTP.

L'analisi delle versioni ha permesso di identificare il server web:

`Apache httpd 2.2.22 (Ubuntu)`

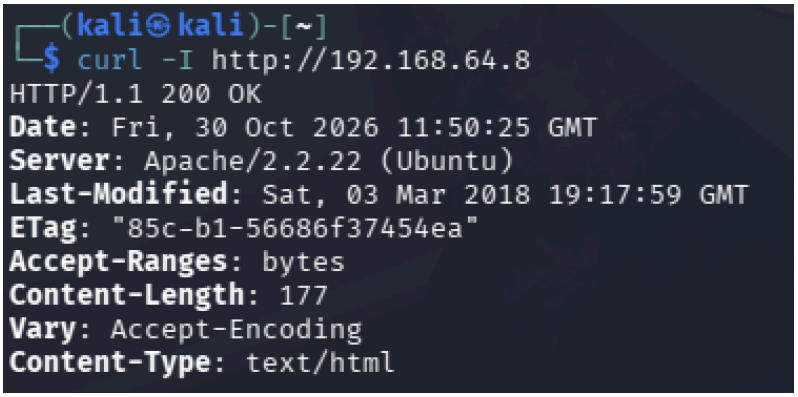
Per verificare la risposta del server è stato utilizzato il comando:

`curl -I http://192.168.64.8`

Il server ha restituito:

`HTTP/1.1 200 OK`

Il risultato conferma che il servizio HTTP è attivo e raggiungibile dalla macchina Kali Linux.



6.2 Scansione delle vulnerabilità tramite Nmap

Dopo aver identificato il servizio HTTP, è stata effettuata un'ulteriore scansione utilizzando gli script NSE (Nmap Scripting Engine), con l'obiettivo di individuare eventuali vulnerabilità e informazioni aggiuntive sui servizi esposti.

Il comando utilizzato è stato:

```
nmap --script vuln 192.168.64.8
```

Il comando è composto da:

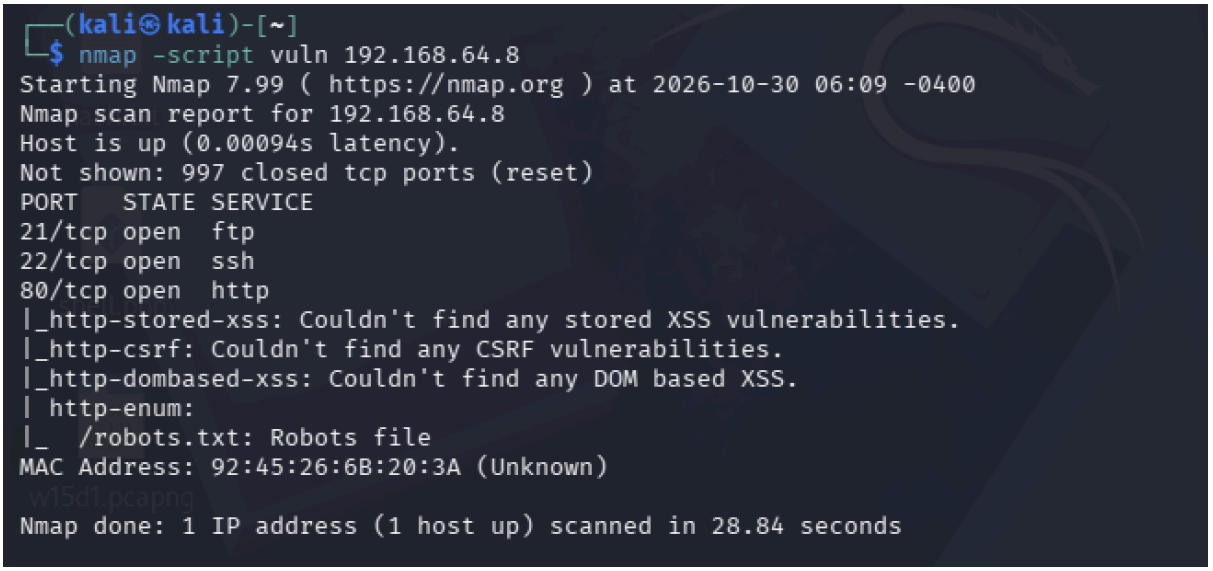
- `nmap`: avvia lo strumento di scansione.
- `--script vuln`: esegue gli script NSE appartenenti alla categoria `vuln`, utilizzati per verificare possibili vulnerabilità note.
- `192.168.64.8`: indica l'indirizzo IP della macchina bersaglio.

La scansione ha fornito ulteriori informazioni sui servizi disponibili, contribuendo all'individuazione di una possibile installazione WordPress sul server HTTP.

Durante l'analisi dei risultati è stato individuato il percorso:

```
/robots.txt
```

Questo elemento ha portato ad approfondire l'analisi del servizio web, verificando la presenza di un'installazione WordPress nella directory individuata.



6.3 Analisi del file robots.txt

Dopo aver individuato il file `robots.txt` tramite Nmap, è stato utilizzato il browser Firefox per verificarne il contenuto.

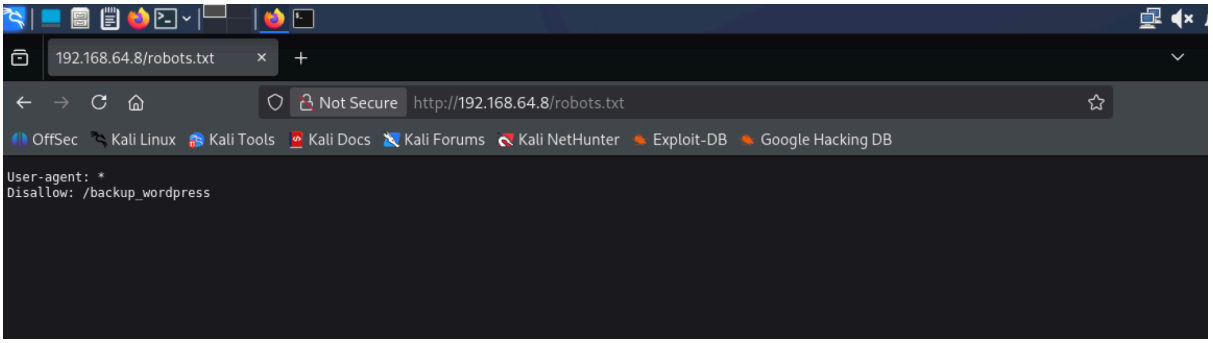
È stato aperto il seguente indirizzo:

`http://192.168.64.8/robots.txt`

Durante la visualizzazione del file è stata individuata la directory:

`/backup_wordpress/`

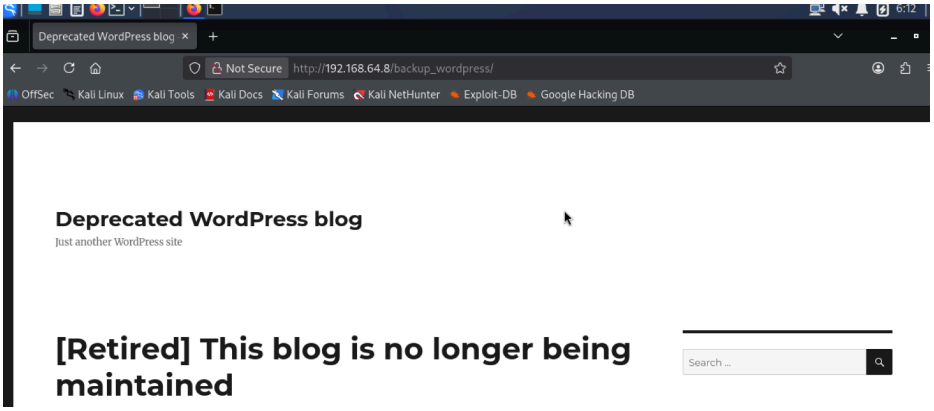
Questa informazione ha consentito di identificare un nuovo percorso da analizzare sul server web.



6.4 Verifica dell'installazione WordPress

Dopo aver individuato il percorso nel file `robots.txt`, è stata verificata la disponibilità della directory tramite Firefox, utilizzando il seguente indirizzo:

`http://192.168.64.8/backup_wordpress/`



6.5 Analisi di enumerazione WordPress tramite Metasploit Framework

Dopo aver confermato la presenza di WordPress, è stata effettuata un'ulteriore analisi utilizzando **Metasploit Framework**, con l'obiettivo di raccogliere informazioni sull'installazione e verificare l'eventuale presenza di componenti identificabili.

È stata avviata la console di Metasploit:

```
msfconsole
```

Successivamente è stato ricercato il modulo dedicato alla scansione WordPress:

```
search wordpress_scanner
```

È stato individuato il modulo:

```
auxiliary/scanner/http/wordpress_scanner
```

```
   238  auxiliary/scanner/http/wordpress_scanner                    .                normal     No     Wordpress Scanner
```

Il modulo è stato selezionato mediante:

```
use auxiliary/scanner/http/wordpress_scanner
```

Per visualizzare le opzioni disponibili è stato utilizzato:

```
show options
```

Il modulo è stato configurato per analizzare il server HTTP della macchina bersaglio e il percorso dell'installazione WordPress:

```
set RHOSTS 192.168.64.8
```

```
set TARGETURI /backup_wordpress
```

La scansione è stata quindi avviata tramite:



```
msf auxiliary(scanner/http/wordpress_scanner) > show options

Module options (auxiliary/scanner/http/wordpress_scanner):

   Name                Current Setting                       Required  Description
   ----                ---------------                       --------  -----------
   EXPLOITABLE         true                                  no        Only scan plugins and themes which a MSF module exists for
   EXPLOITABLE_PLUGINS /usr/share/metasploit-framework/dat   yes       File containing exploitable by MSF plugins
                       a/wordlists/wp-exploitable-plugins.
                       txt
   EXPLOITABLE_THEMES  /usr/share/metasploit-framework/dat   yes       File containing exploitable by MSF themes
                       a/wordlists/wp-exploitable-themes.t
                       xt
   PLUGINS             true                                  no        Detect plugins
   PLUGINS_FILE        /usr/share/metasploit-framework/dat   yes       File containing plugins to enumerate
                       a/wordlists/wp-plugins.txt
   PROGRESS            1000                                  yes       how often to print progress
   Proxies                                                   no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Su
                                                                       pported proxies: sapni, http, socks4, socks5, socks5h
   RHOSTS              192.168.64.8                          yes       The target host(s), see https://docs.metasploit.com/docs/using-m
                                                                       etasploit/basics/using-metasploit.html
   RPORT               80                                    yes       The target port (TCP)
   SSL                 false                                 no        Negotiate SSL/TLS for outgoing connections
   TARGETURI           /backup_wordpress                     yes       The base path to the wordpress application
   THEMES              true                                  no        Detect themes
   THEMES_FILE         /usr/share/metasploit-framework/dat   yes       File containing themes to enumerate
                       a/wordlists/wp-themes.txt
   THREADS             1                                     yes       The number of concurrent threads (max one per host)
   USERS               true                                  no        Detect users with API
   VHOST                                                     no        HTTP server virtual host

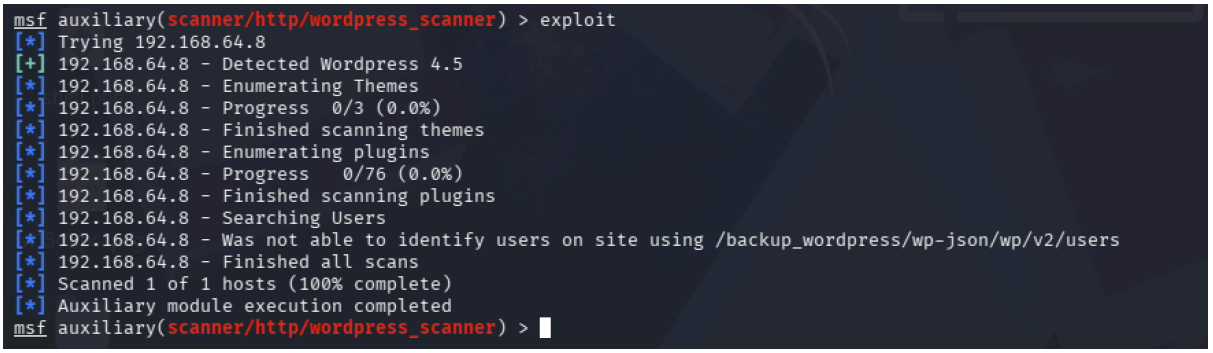
View the full module info with the info, or info -d command.
```

`exploit`

L'utilizzo del modulo `wordpress_scanner` ha consentito di effettuare una verifica mirata sull'installazione WordPress individuata.

Durante le attività di analisi è stata identificata la versione:

`WordPress 4.5`



Risultati dell'analisi:

- Non sono stati individuati plugin vulnerabili confermati.
- Non sono stati individuati temi vulnerabili confermati.
- Non sono state ottenute credenziali amministrative.
- Non è stato dimostrato lo sfruttamento di una vulnerabilità WordPress.

6.6 Valutazione dei risultati e vulnerabilità riscontrate

L'analisi del servizio HTTP ha permesso di individuare un'installazione WordPress attraverso una sequenza di ricognizione ed enumerazione. La scansione Nmap con gli script NSE ha evidenziato la presenza del file `robots.txt`, la cui consultazione tramite Firefox ha rivelato la directory `/backup_wordpress/`. L'accesso alla directory ha confermato la presenza dell'installazione WordPress, successivamente analizzata tramite il modulo Metasploit `auxiliary/scanner/http/wordpress_scanner`.

Elemento di sicurezza rilevato: esposizione di una directory contenente un'installazione WordPress attraverso il file pubblico `robots.txt`.

Descrizione: il file `robots.txt` ha permesso di individuare il percorso `/backup_wordpress/`, rendendo facilmente identificabile un'applicazione web presente sul server.

Impatto dimostrato: individuazione della directory WordPress e possibilità di effettuare ulteriori attività di enumerazione dell'applicazione.

Risultato della scansione Auxiliary: nessuna vulnerabilità WordPress sfruttabile confermata durante le verifiche svolte.

Esito: esposizione del percorso WordPress confermata; nessuna compromissione dell'applicazione web dimostrata.

---

7. Analisi del servizio SSH

7.1 Individuazione del modulo Metasploit

La scansione iniziale ha evidenziato la presenza del servizio SSH sulla porta 22.

Per verificare la sicurezza delle credenziali di accesso è stato ricercato il modulo Metasploit:

```
search ssh_login
```

Il risultato ha individuato:

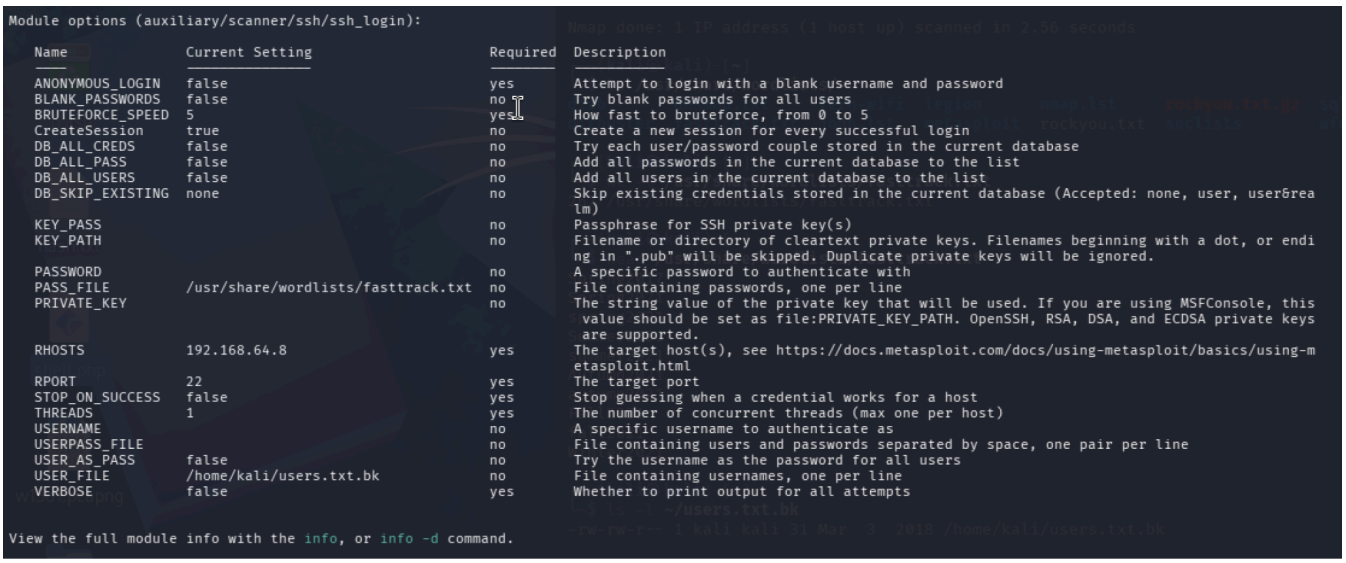
```
auxiliary/scanner/ssh/ssh_login
```

Il modulo è stato selezionato tramite:

```
use 0
```

Le opzioni disponibili sono state visualizzate con:

```
show options
```



```
Module options (auxiliary/scanner/ssh/ssh_login):

   Name              Current Setting                    Required  Description
   ----              ---------------                    --------  -----------
   ANONYMOUS_LOGIN   false                              yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS   false                              no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                                  yes       How fast to bruteforce, from 0 to 5
   CreateSession     true                               no        Create a new session for every successful login
   DB_ALL_CREDS      false                              no        Try each user/password couple stored in the current database
   DB_ALL_PASS       false                              no        Add all passwords in the current database to the list
   DB_ALL_USERS      false                              no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none                               no        Skip existing credentials stored in the current database (Accepted: none, user, user&rea
                                                                  lm)
   KEY_PASS                                             no        Passphrase for SSH private key(s)
   KEY_PATH                                             no        Filename or directory of cleartext private keys. Filenames beginning with a dot, or endi
                                                                  ng in ".pub" will be skipped. Duplicate private keys will be ignored.
   PASSWORD                                             no        A specific password to authenticate with
   PASS_FILE         /usr/share/wordlists/fasttrack.txt no        File containing passwords, one per line
   PRIVATE_KEY                                          no        The string value of the private key that will be used. If you are using MSFConsole, this
                                                                   value should be set as file:PRIVATE_KEY_PATH. OpenSSH, RSA, DSA, and ECDSA private keys
                                                                   are supported.
   RHOSTS            192.168.64.8                       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-m
                                                                  etasploit.html
   RPORT             22                                 yes       The target port
   STOP_ON_SUCCESS   false                              yes       Stop guessing when a credential works for a host
   THREADS           1                                  yes       The number of concurrent threads (max one per host)
   USERNAME                                             no        A specific username to authenticate as
   USERPASS_FILE                                        no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS      false                              no        Try the username as the password for all users
   USER_FILE         /home/kali/users.txt.bk            no        File containing usernames, one per line
   VERBOSE           false                              yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.
```

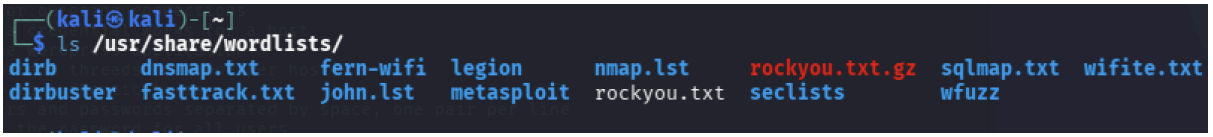
7.2 Individuazione e analisi della wordlist per il test SSH

Dopo aver recuperato dal servizio FTP il file `users.txt.bk`, contenente gli username presenti sulla macchina bersaglio, è stato necessario individuare una lista di password da utilizzare per verificare la robustezza delle credenziali SSH.

A tale scopo è stata esaminata la directory `/usr/share/wordlists/` di Kali Linux, destinata a contenere wordlist utilizzabili durante le attività di penetration testing.

Per visualizzare i file disponibili è stato utilizzato il comando:

```
ls /usr/share/wordlists/
```



```
┌──(kali㉿kali)-[~]
└─$ ls /usr/share/wordlists/
dirb        dnsmap.txt    fern-wifi  legion      nmap.lst     rockyou.txt.gz  sqlmap.txt  wifite.txt
dirbuster   fasttrack.txt  john.lst   metasploit  rockyou.txt  seclists        wfuzz
```

Tra le wordlist disponibili è stata individuata `fasttrack.txt`, una lista di password comuni utilizzabile per effettuare un test di autenticazione.

Il percorso completo del file selezionato è:

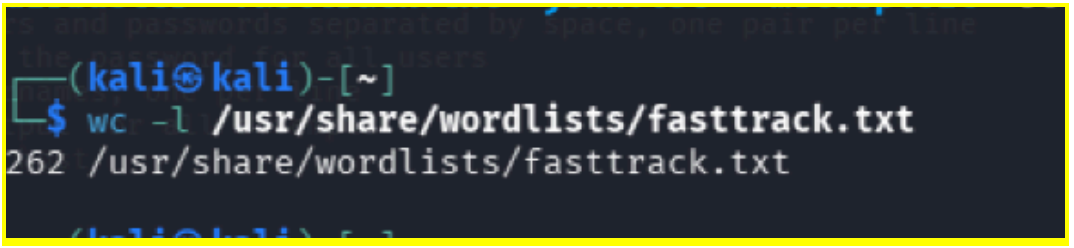
```
/usr/share/wordlists/fasttrack.txt
```

Successivamente, per verificare il numero di righe contenute nella wordlist, è stato eseguito:

```
wc -l /usr/share/wordlists/fasttrack.txt
```

Il comando ha restituito:

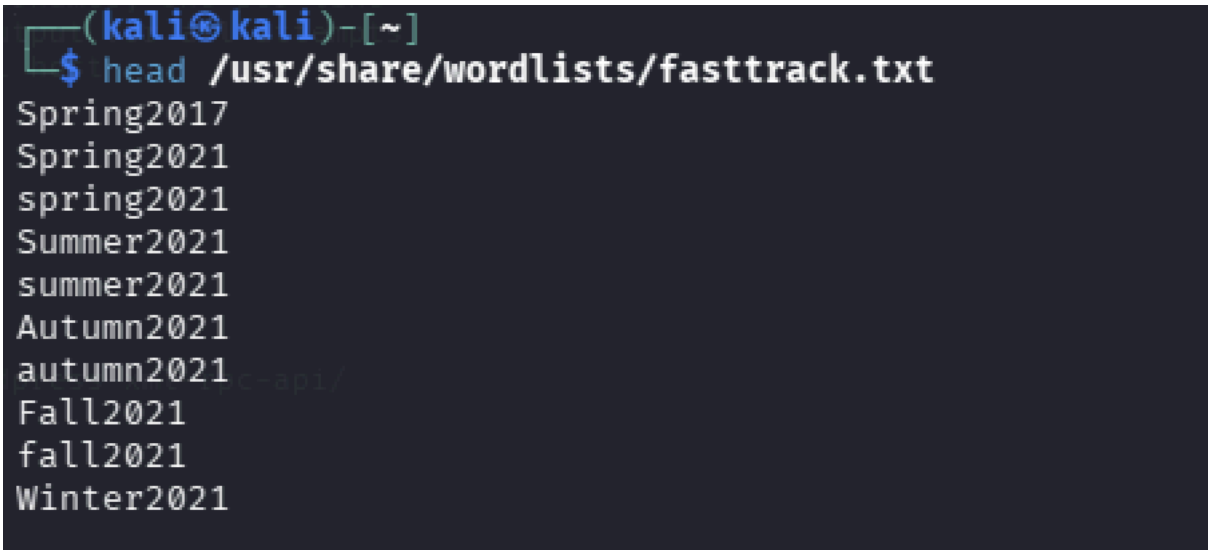
```
262 /usr/share/wordlists/fasttrack.txt
```



Il risultato indica che il file contiene 262 righe.

Per esaminare le prime voci della wordlist è stato utilizzato:

```
head /usr/share/wordlists/fasttrack.txt
```



Questa verifica ha permesso di controllare il contenuto iniziale del file prima del suo utilizzo nel modulo Metasploit `auxiliary/scanner/ssh/ssh_login`.

7.3 Configurazione del modulo Metasploit per la verifica delle credenziali SSH

Dopo aver individuato il modulo `auxiliary/scanner/ssh/ssh_login` e aver analizzato la wordlist `fasttrack.txt`, si è proceduto alla configurazione dei parametri necessari per effettuare il test di autenticazione SSH. L'obiettivo era verificare se uno degli username recuperati precedentemente tramite FTP utilizzasse una password contenuta nella wordlist selezionata.

7.4 Configurazione della macchina bersaglio

Il primo parametro configurato è stato `RHOSTS`, che indica l'indirizzo IP della macchina sulla quale effettuare il test.

All'interno del modulo Metasploit è stato eseguito:

```
set RHOSTS 192.168.64.8
```

L'indirizzo `192.168.64.8` corrisponde alla macchina BSides Vancouver 2018 Workshop, precedentemente identificata durante la ricognizione.

Il servizio SSH era stato individuato sulla porta `22/TCP` attraverso la scansione Nmap.

7.5 Configurazione degli username

Successivamente è stato configurato il parametro `USER_FILE`, utilizzato per indicare il file contenente i nomi utente da sottoporre alla verifica.

È stato eseguito:

```
set USER_FILE /home/kali/users.txt.bk
```

Il file `users.txt.bk` era stato recuperato durante l'analisi del servizio FTP e conteneva cinque username:

- **abatchy**
- **john**
- **mai**
- **anne**
- **doomguy**

Il parametro `USER_FILE` ha quindi permesso a Metasploit di utilizzare gli username precedentemente individuati, senza doverli inserire manualmente uno alla volta.

7.6 Configurazione della wordlist delle password

Dopo aver indicato gli username, è stato configurato il parametro `PASS_FILE`, utilizzato per specificare il percorso del file contenente le password da verificare.

È stato eseguito:

```
set PASS_FILE /usr/share/wordlists/fasttrack.txt
```

La wordlist `fasttrack.txt`, già analizzata, conteneva 262 righe.

Attraverso questa configurazione, il modulo avrebbe utilizzato le password presenti nella wordlist per effettuare tentativi di autenticazione con gli username contenuti nel file `users.txt.bk`.

In questo modo sono state collegate le informazioni ottenute durante l'enumerazione FTP con quelle presenti nella wordlist di Kali Linux.

7.7 Attivazione della modalità dettagliata

Per osservare i tentativi effettuati durante l'esecuzione del test, è stata abilitata la modalità dettagliata tramite:

```
set VERBOSE true
```

Il parametro `VERBOSE`, impostato su `true`, consente di visualizzare informazioni aggiuntive sui tentativi di autenticazione effettuati dal modulo.

7.8 Verifica della configurazione

Una volta impostati i parametri, è stato utilizzato:

```
show options
```

Il comando ha permesso di verificare che il modulo fosse configurato con i seguenti valori:

```
RHOSTS     192.168.64.8

USER_FILE  /home/kali/users.txt.bk

PASS_FILE  /usr/share/wordlists/fasttrack.txt

VERBOSE    true
```



La configurazione risultava quindi pronta per la verifica delle credenziali SSH.

7.9 Esecuzione della verifica delle credenziali SSH

Terminata la configurazione del modulo `auxiliary/scanner/ssh/ssh_login`, è stata avviata la verifica delle credenziali attraverso il comando:

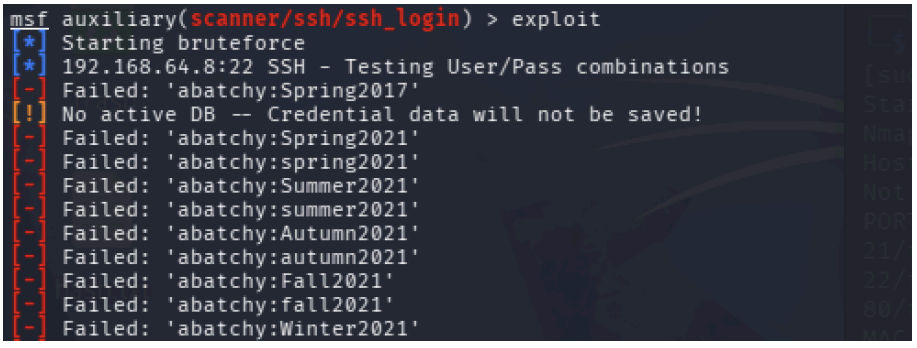
```
exploit
```

Il modulo ha iniziato a verificare le combinazioni tra gli username presenti nel file `users.txt.bk` e le password contenute nella wordlist `fasttrack.txt`.

Per ciascuna combinazione sottoposta a verifica, Metasploit ha tentato di effettuare un'autenticazione al servizio SSH della macchina bersaglio.

La modalità `VERBOSE true` ha consentito di visualizzare i messaggi relativi ai tentativi effettuati.

È importante precisare che il modulo utilizzato appartiene alla categoria `auxiliary/scanner`: il test era finalizzato alla verifica delle credenziali, non allo sfruttamento di una vulnerabilità del software SSH.



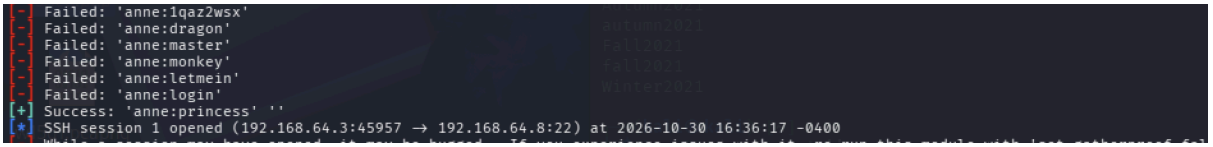
7.10 Individuazione delle credenziali valide

Durante l'esecuzione del test, Metasploit ha individuato una combinazione di username e password valida.

Il risultato positivo è stato segnalato dal messaggio:

`[+] Success: 'anne:princess'`

Questo risultato indica che il servizio SSH ha accettato le credenziali associate all'utente `anne`.



Le credenziali individuate sono state:

`Username: anne`

`Password: princess`

Il modulo ha inoltre segnalato l'apertura di una sessione SSH, confermando la validità delle credenziali.

Dopo aver ottenuto il risultato positivo, i tentativi successivi sono stati interrotti, poiché era già stata individuata una combinazione valida per proseguire con la verifica dell'accesso al sistema.

7.11 Vulnerabilità riscontrata ed esito del test

Vulnerabilità: password SSH individuabile mediante attacco a dizionario.

Servizio interessato: SSH – porta `22/TCP`.

Account coinvolto: `anne`.

Descrizione: durante il test di autenticazione effettuato tramite il modulo Metasploit `auxiliary/scanner/ssh/ssh_login`, è stata individuata una password valida per l'utente `anne`, utilizzando la wordlist `fasttrack.txt`.

La vulnerabilità è stata dimostrata attraverso la combinazione degli username recuperati dal servizio FTP e delle password contenute nella wordlist.

Impatto dimostrato: individuazione di credenziali valide e apertura di una sessione SSH autenticata.

Esito: vulnerabilità confermata. Le credenziali `anne:princess` sono risultate valide e hanno consentito di proseguire con la successiva fase di verifica dell'accesso SSH e dei privilegi dell'utente.

---

8. Accesso alla macchina tramite SSH

8.1 Autenticazione con le credenziali individuate

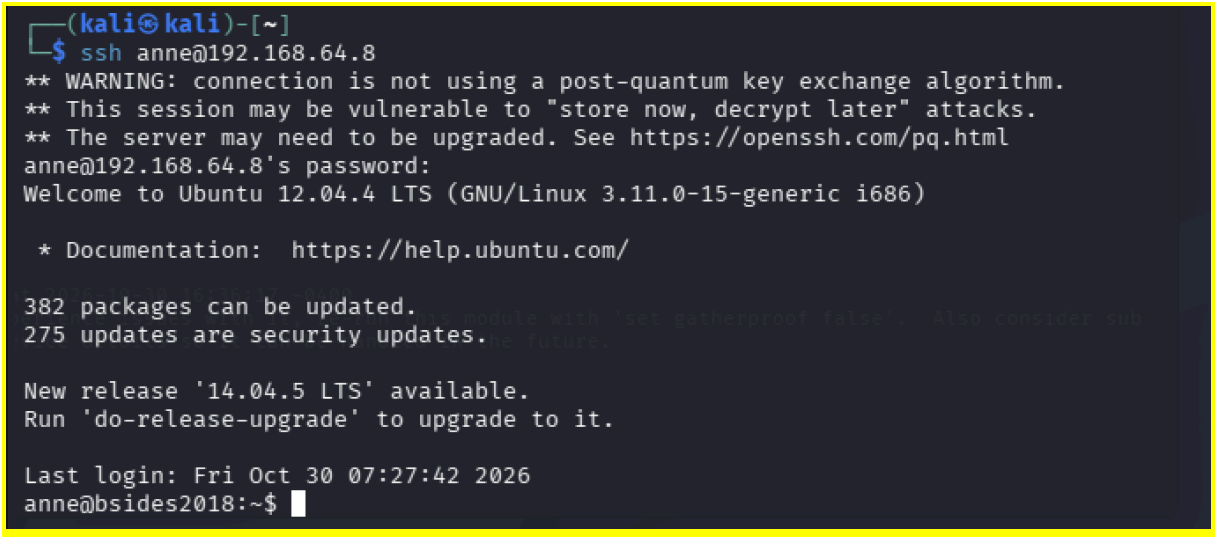
Per confermare il risultato ottenuto tramite Metasploit è stata effettuata una connessione SSH manuale:

`ssh anne@192.168.64.8`

Dopo aver inserito la password precedentemente individuata, l'autenticazione è avvenuta correttamente.

Il terminale ha mostrato:

`anne@bsides2018:~$`



L'accesso ha permesso di identificare ulteriori informazioni sul sistema:

- **Sistema operativo:** Ubuntu 12.04.4 LTS
- **Kernel:** Linux 3.11.0-15-generic
- **Hostname:** bsides2018

---

9. Verifica dei privilegi e Privilege Escalation

9.1 Identificazione dei privilegi dell'utente

Dopo aver ottenuto l'accesso SSH è stato eseguito:

`id`

Il comando ha restituito:

`uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)`

```
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
```

L'output dimostra che l'utente anne appartiene al gruppo sudo.

9.2 Verifica delle autorizzazioni amministrative

Per verificare i privilegi disponibili è stato utilizzato:

`sudo -l`

Il sistema ha restituito:

`User anne may run the following commands on this host:`

`    (ALL : ALL) ALL`

Il risultato indica che l'utente può eseguire qualsiasi comando tramite sudo, dopo essersi autenticato.

```
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$
```

9.3 Ottenimento dei privilegi root

Per ottenere una shell amministrativa è stato eseguito:

`sudo su`

Il prompt è cambiato in:

`root@bsides2018:/home/anne#`

Per verificare l'identità dell'utente corrente è stato utilizzato:

`whoami`

Il risultato è stato:

`root`

```
root@bsides2018:/home/anne# whoami
root
root@bsides2018:/home/anne#
```

Infine, per verificare i privilegi effettivi, è stato eseguito:

`id`

Il comando ha restituito:

`uid=0(root) gid=0(root) groups=0(root)`

Questo risultato conferma l'ottenimento dei privilegi amministrativi completi.

```
root@bsides2018:/home/anne#  id
uid=0(root) gid=0(root) groups=0(root)
```

9.4 Vulnerabilità riscontrata

Vulnerabilità: compromissione di un account SSH dotato di privilegi amministrativi completi.

Descrizione: l'account `anne`, accessibile mediante una password individuata con un attacco a dizionario, dispone delle autorizzazioni necessarie per eseguire qualsiasi comando tramite `sudo`.

Impatto dimostrato: compromissione completa della macchina bersaglio con ottenimento dei privilegi `root`.

Esito: ottenimento dei privilegi root riuscito.

10. Risultati conclusivi

L'attività di Vulnerability Assessment e Penetration Test sulla macchina BSides Vancouver 2018 Workshop ha consentito di individuare e verificare diverse debolezze di sicurezza. La fase iniziale di ricognizione ha permesso di identificare l'indirizzo IP della macchina bersaglio, successivamente utilizzato per la scansione delle porte e l'analisi dei servizi. La scansione Nmap ha individuato tre servizi esposti: FTP, SSH e HTTP. L'analisi del servizio FTP ha evidenziato la possibilità di effettuare un accesso anonimo e recuperare un file contenente cinque nomi utente. Le informazioni ottenute sono state successivamente utilizzate per verificare le credenziali SSH mediante Metasploit Framework. La verifica ha individuato una combinazione valida per l'utente `anne`, consentendo l'accesso al sistema operativo della macchina bersaglio. L'analisi dei privilegi ha dimostrato che l'account compromesso disponeva di autorizzazioni amministrative complete attraverso `sudo`. L'esecuzione dei comandi `sudo su`, `whoami` e `id` ha confermato l'ottenimento dei privilegi `root`. Il Penetration Test ha quindi dimostrato una catena di compromissione completa, dall'esposizione di informazioni tramite FTP fino all'ottenimento del controllo amministrativo della macchina bersaglio.

Vincenzo Lembo